Future Plans

Production-Readiness & Product Roadmap for the Industrial Robotics Security Platform

Companion to the Topic-114 platform. The system today is a complete, verified teaching/reference build: a single-homed IEC-62443 Level-3.5 IDMZ, a dual-plane AI detector (Modbus + robot behavior), a GPG-signed OT deploy pipeline, and playbook-driven incident response. This document is the honest path from that to a hardened, fleet-scale product.

> **HOW TO READ THIS**
> The platform is intentionally a lab today (shared API key, at-rest secrets, software safety simulator, single host). That is appropriate for its purpose. Everything below is the gap to production and the features that would make it a compelling commercial OT-security product — grouped so each item is independently buildable.

A. Production-Hardening Roadmap

These close the lab→production gap. They do not add features; they make the existing capabilities safe to connect to something that can move.

A1. Identity, access & trust

- **Per-identity authN + RBAC** to replace the single shared API key; distinct operator / SOC-analyst / auditor / vendor roles with least privilege on every state-changing route.
- **mTLS between services** (SPIFFE/SPIRE or a service mesh) so a stolen key alone cannot impersonate a component.
- **Signed, dual-control approvals** for IR actions and any control intent — cryptographic, not just a UI click.
- **SSO / OIDC** integration for enterprise identity; full audit of who did what, when.

A2. Secrets & supply chain

- **Vault / KMS / SOPS** for all secrets with per-service scoping and rotation; stop shipping `.env` into containers.
- **HSM/KMS-backed signing** for the Stage-5 deploy key (today it is an ephemeral in-container GPG key), with **SLSA provenance** and verified build attestation, not just a detached signature.
- **Pinned dependencies + SBOM** (CycloneDX) and real CI scanners (Trivy, pip-audit, Grype) as blocking gates, replacing the static vulnerabilities.json.

A3. Functional safety independence

- **Hardware/logically-independent SIS** (IEC 61511): a real safety PLC or safety relay, not a software simulator co-located with the controller.
- **Local-only E-stop reset** — no network un-latch path of any kind; watchdog + latch + replay-guard in the *running* controller (the design already specifies these).
- **Hard-wired de-energize** path independent of the network and the analytics plane.

> **WHY IT MATTERS**
> A monitoring platform must never be on the safety-critical path. The roadmap keeps detection/response advisory to an independent SIS that can always fail the cell to a safe state on its own.

A4. Resilience & trustworthy telemetry

- **Process supervision** (s6 / systemd / Kubernetes) with real liveness + readiness probes per service (not just a Redis ping), and durable, audited incident state that survives restarts.
- **Central, append-only, tamper-evident log/metric store** shipped off-box (signed); the dashboard reads views, never the source of truth.
- **Reconnect safety telemetry across the IDMZ (Gap G-1):** have the OT-resident SEC sensor read the safety registers and ship state via Redis (the same pattern Modbus features already use), so the firewall stays closed and the safety panel goes live instead of reading -1.
- **Re-scope monitoring probes (Gap G-2):** point lab_exporter at IDMZ addresses and per-zone reachability so component tiles reflect reality.

A5. Container & edge hardening

- Non-root users, distroless multi-stage images, read-only root filesystem, `cap_drop: [ALL]` + only required caps.
- Per-zone hosts/VLANs in a real plant (the single-host Docker model is the lab compression of that); optional true data-diode on the OT→analytics path.
- HTTP→HTTPS everywhere, security headers, authenticated Prometheus/Grafana, tightened CORS.

B. AI Engine Upgrades

The detector is genuinely good (dual-plane, anti-drift feature module, live-calibrated thresholds). These upgrades make it more accurate, self-maintaining, and explainable.

B1. Train on real data, end the train/serve skew permanently

- Capture a **clean live baseline** (real Zeek Modbus features + real Gazebo /joint_states) and train "normal" on it; keep synthetic data only for **labeled attacks / AUC evaluation** (you cannot safely harvest real attacks).
- This retires the recalibration band-aid: the model learns the real pipeline shape (multi-row, bursty) out of the box.

> **TRADE-OFF / BE HONEST**
> We already hit and fixed this: synthetic-only calibration made the autoencoders flag normal traffic. Training "normal" on real capture is the permanent fix and matches the project's "real dataset" direction.

B2. Self-maintaining models

- **Drift monitoring + guarded auto-recalibration**: detect distribution shift, recalibrate within bounds, alert when out of bounds.
- **Model registry + versioning** with shadow / A-B scoring and signed model artifacts pulled the same way PLC code is.
- **Online / incremental learning** for slow legitimate process changes, with human sign-off before promotion.

B3. Broader & deeper detection

- **More protocol planes:** DNP3 and OPC-UA detectors (Zeek already parses them) alongside Modbus.
- **Process-physics / multivariate models:** cross-signal correlation (current vs torque vs position) to catch stealthy cyber-physical attacks that look normal per-signal.
- **Sequence/transformer temporal models** for multi-step attack patterns; few-shot adaptation for new robot types.
- **Adversarial robustness** against evasion; expand the attack simulator and map every attack to **MITRE ATT&CK for ICS**.

B4. Explainability

- Surface **feature attributions (SHAP)** per alert in the UI (today we expose top-features — make it first-class with packet drill-down).
- **Natural-language alert summaries** ("FC6 write burst from a non-OT source at 7x baseline rate") for operators.
- **Federated / fleet learning** across plants (privacy-preserving) for rare-attack generalization.

C. Dashboard Improvements

The operator UI is the product's face. These raise it from a solid lab dashboard to a SOC-grade console.

C1. Real-time & robustness

- **WebSocket / SSE push** instead of 5s polling — instant updates, less load.
- **Keep-last-value on a metric miss** (the trend panel already does this) so a momentary gap never blanks a tile.
- **Live IDMZ topology map** showing zones, the 8 conduits, and pass/fail of the segmentation matrix in real time.

C2. Investigation & response

- **Incident timeline / case management** with a kill-chain view and MITRE ATT&CK for ICS overlay.
- **Drill-down:** anomaly → feature contributions → raw Zeek records / pcap.
- **SOAR-grade IR:** richer playbooks, case notes, and integrations (email / Slack / PagerDuty / SIEM / syslog / Splunk).

C3. Roles, compliance & reporting

- **Role-based views** (operator vs SOC analyst vs auditor) + responsive/mobile + dark mode.
- **Compliance dashboard:** live IEC-62443 / NIST 800-82 control mapping with one-click evidence export (PDF).
- **Ops analytics:** MTTD/MTTR, SLA tracking, anomaly heatmaps, historical trend explorer.

D. New Features (make it more impressive)

- **Digital twin & what-if simulation** — replay attacks against a twin to validate detections and train operators safely.
- **Fleet / multi-cell scale** — many robots/plants, central SOC (the hybrid-cloud target), per-site policy.
- **Multi-protocol OT** — EtherNet/IP, PROFINET, S7comm, BACnet beyond Modbus/ROS2.
- **Zero-trust OT** — per-message authenticated control through the gateway; continuous device authentication/posture.
- **Threat-intel integration** — CVE / ICS-CERT advisory feeds auto-correlated with the asset inventory.
- **Continuous purple-team (BAS for OT)** — scheduled, safe attack simulation that proves detections still work.
- **OT deception** — honeypot PLC/robot decoys in a sacrificial segment to catch lateral movement early.
- **Compliance automation expansion** — NERC CIP / NIST 800-82 / ISA-62443 evidence generation and gap reports.

E. Prioritized Roadmap

A pragmatic sequencing by impact vs effort. "Now" items are the credibility-critical hardening; "Next" makes it self-maintaining and SOC-usable; "Later" is the differentiated product surface.

Horizon	Theme	Headline items	Why now
Now	Safety + trust	Independent SIS & local-only reset; reconnect safety telemetry (G-1); fail-closed per-identity auth; secrets in a vault	Disqualifying for any live cell until done
Now	Supply chain	HSM-backed signing + SLSA provenance; SBOM + real scanners as CI gates	Makes the signed-deploy story production-true
Next	AI	Train normal on real capture; drift monitor + model registry; DNP3/OPC-UA planes	Ends train/serve skew; broadens coverage
Next	Dashboard	WebSocket push; incident/case mgmt + ATT&CK-ICS; live IDMZ map; SIEM/Slack integrations	Turns the UI into a SOC console
Next	Resilience	Process supervision; durable audited state; central tamper-evident log store	Survives restarts; trustworthy evidence
Later	Scale	Fleet / multi-cell + hybrid-cloud SOC; multi-protocol OT	Multi-plant product
Later	Differentiators	Digital twin; zero-trust OT; OT deception; continuous purple-team	Stand-out capabilities

---

Generated as the forward-looking companion to REQUIREMENTS-COMPLIANCE-AUDIT.md and ARCHITECTURE-DIAGRAMS.md. Each item is scoped to be independently buildable on the current IDMZ base.